

1. Identificacion del contrato

|                 |                                                                                                                                                                          |
|-----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Proposito       | Campana de financiacion colectiva: los usuarios aportan ETH hacia una meta (goal) antes de un deadline; el owner retira los fondos y los aportantes pueden reembolsarse. |
| Actores         | Owner (despliega, retira), Aportantes (contribute/refund). Sin protocolos externos.                                                                                      |
| Flujo de fondos | ETH entra por contribute() y queda en el contrato. Sale por withdrawAll() (owner) o refund() (aportante).                                                                |

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

| # | Riesgo / Causa raiz                                                                                                                                                             | Descripcion y vector de ataque                                                                                                                                                                                                                                                                                                  | Sev.     | SWC     | OWASP 2026                      |
|---|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|---------|---------------------------------|
| 1 | <b>Reembolso repetible / Reentrancy en refund()</b><br>Root: No se actualiza el estado (contributions) antes/despues de la transferencia; se viola Checks-Effects-Interactions. | refund() envia ETH con call() pero NUNCA pone contributions[msg.sender] a 0. El aportante puede reentrar o simplemente volver a llamar refund() en transacciones sucesivas y drenar fondos de otros.<br><b>Vector:</b> Tras el deadline, un aportante llama refund() en bucle (reentrante o repetido) hasta vaciar el contrato. | Critical | SWC-107 | SC08:2026 Reentrancy            |
| 2 | <b>Owner puede retirar todo sin condiciones (rug pull)</b><br>Root: Logica de exito de campana ausente; goal declarado pero no validado.                                        | withdrawAll() permite al owner llevarse address(this).balance en cualquier momento, sin comprobar si se alcanzo goal ni si paso el deadline. La variable goal nunca se usa.<br><b>Vector:</b> El owner llama withdrawAll() y se queda con todas las aportaciones, dejando insolvente a refund().                                | High     | SWC-105 | SC02:2026 Business Logic Errors |
| 3 | <b>Carrera de fondos entre owner y aportantes</b><br>Root: Contabilidad unica sin segregar fondos por estado de campana.                                                        | withdrawAll() y refund() compiten por el mismo balance; quien ejecute primero deja sin fondos al otro. No hay separacion contable.<br><b>Vector:</b> Front-running entre owner y aportantes para vaciar el balance comun.                                                                                                       | Medium   | SWC-114 | SC02:2026 Business Logic Errors |

3. Analisis de logica de negocio

|                                                                                                                                                     |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| goal nunca se comprueba; no existe estado de exito/fracaso; refund no exige haber fallado la meta; insolvencia garantizada si owner retira primero. |
|-----------------------------------------------------------------------------------------------------------------------------------------------------|

6. Benchmark metrics

|            |               |           |             |          |                    |                   |                  |                |            |
|------------|---------------|-----------|-------------|----------|--------------------|-------------------|------------------|----------------|------------|
| 3<br>Total | 1<br>Critical | 1<br>High | 1<br>Medium | 0<br>Low | 0.92<br>Confidence | 0.90<br>Precision | 1.00<br>Coverage | 55<br>Time (s) | 82<br>Risk |
|------------|---------------|-----------|-------------|----------|--------------------|-------------------|------------------|----------------|------------|

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).